The Plan Processor is already required to establish policies and procedures and a cyber incident response plan pursuant to Section 4.1.5 of the CAT NMS Plan, so the Commission believes it is appropriate to estimate a burden of revising breach management policies and procedures and the cyber incident response plan relate to the new elements required by proposed Section 4.1.5 of the CAT NMS Plan. The Commission preliminarily believes that these requirements would result in a one-time external cost of $49,805 for Participants, or $1,992.20 per Participant,[584] based on the Commission's estimation that it would require approximately 124 Plan Processor staff hours to incorporate the new elements required by proposed Section 4.1.5 of the CAT NMS Plan.[585] The Commission believes that there would be an initial internal burden of 25 hours for the Participants, or 1 hour per Participant[586] for review and approval of the updated cyber incident response plan by the Operating Committee.

Further, the Commission estimates that the Participants will incur an aggregate ongoing external cost of $42,205, or $1,688.20 for each individual Participant,[587] for Plan Processor staff time required to maintain, update and enforce these policies and procedures and the cyber

---

584 $49,805 / 25 Participants = $1,992.20 per Participant.

585 The estimate of 124 hours of Plan Processor staff time include 32 hours by an Attorney, 32 hours by a Compliance Manager, 10 hours by a Senior Systems Analyst, 10 hours by an Operations Specialist, 20 hours by the Chief Compliance Officer and 20 hours by the Chief Information Security Officer. The Commission is basing this estimation on the estimated initial burden to implement corrective action processes required by Rule 1002(a) of Regulation SCI. See Regulation SCI Adopting Release, supra note 54, at 72393. The total estimated one-time external cost for Participants is $49,805 = (Attorney for 32 hours at $426 per hour = $13,631) + (Compliance Manager for 32 hours at $317 per hour = $10,144) + (Senior Systems Analyst for 10 hours at $291 per hour = $2,910) + (Operations Specialist for 10 hours at $140 per hour = $1,400) + (Chief Compliance Officer for 20 hours at $543 per hour = $10,860) + (Chief Information Security Officer at $543 per hour = $10,860).

586 25 hours / 25 Participants = 1 hour per Participant.

587 $42,205 / 25 Participants = $1,688.20 per Participant.

incident response plan, which the Commission estimates would be 103 hours of Plan Processor staff time annually.[588] This external cost estimate includes enforcement of the requirements of the cyber incident response plan relating to the proposed breach notification requirement,[589] as well as staff time for documenting breaches that the Plan processor reasonably estimates would have no impact or a de minimis impact on the Plan Processor's operations or on market participants.[590]

---

588 The estimated aggregate ongoing external cost is based on an estimate of 103 hours of Plan Processor staff time that includes 23 hours by an Attorney, 23 hours by a Compliance Manager, 16 hours by a Senior Systems Analyst, 3 hours by an Operations Specialist, 9 hours by an Assistant General Counsel, 17 hours by the Chief Compliance Officer and 12 hours by the Chief Information Security Officer. The Commission is basing this estimate on the ongoing burden to implement corrective action processes required by Rule 1002(a) of Regulation SCI and estimated burden for providing written notifications of Regulation SCI events under Rule 1002(b)(2). See Regulation SCI Adopting Release, supra note 54 at 72384 and 72393-94. The estimated aggregate ongoing external cost is preliminarily estimated to be $42,205 = (Attorney for 23 hours at $426 per hour = $9,798) + (Compliance Manager for 23 hours at $317 per hour = $7,291) + (Senior Systems Analyst for 16 hours at $291 per hour = $4,656) + (Operations Specialist for 3 hours at $140 per hour = $420) + (Assistant General Counsel for 9 hours at $477 per hour = $4,293) + (Chief Compliance Officer for 17 hours at $543 per hour = $9,231) + (Chief Security Officer for 12 hours at $543 per hour = $6,516).

589 The Commission preliminarily estimates that this requirement will require 34 hours of staff time annually from the Plan Processor, resulting in an ongoing annual external cost burden of $13,756 for the Participants, or $550.24 for each Participant ($13,756 / 25 Participants). The 34 hours include 8 hours by an Attorney (Attorney for 8 hours at $426 an hour = $3,408), 8 hours by a Compliance Manager (Compliance Manager for $317 an hour = $2,536), 7 hours by a Senior Systems Analyst (Senior Systems Analyst for 7 hours at $291 an hour = $2,037), 3 hours by an Assistant General Counsel (Assistant General Counsel for 3 hours at $477 per hour = $1,431), 4 hours by a Chief Compliance Officer (Chief Compliance Officer for 4 hours at $543 per hour = $2,172) and 4 hours by the Chief Information Security Officer (Chief Information Security Officer for 4 hours at $543 per hour = $2,172) = $13,756. This estimate relates only to the proposed requirement that the Plan Processor provide breach notifications and does not include other costs related to breaches, such as determination of whether a breach has occurred or assessing the scope of any breach, which is already required by the CAT NMS Plan.

590 The Commission preliminarily estimates that this requirement will require 30 hours of staff time annually from the Plan Processor, resulting in an ongoing annual external cost of $12,324 to the Participants, or $492.96 per Participant ($12,324 / 25 Participants). The

Cumulatively, the Commission preliminarily estimates that to implement the changes proposed in Section 4.1.5 of the CAT NMS Plan, each Participant will incur an initial hourly burden of 1 hour, or 25 hours for all Participants, an initial one-time external cost burden of $1,992.20, or $49,805 for all Participants, and an ongoing annual external cost burden of $42,205 for all Participants, or $1,688.20 for each individual Participant.[591]

10. Customer Information for Allocation Report Firm Designated IDs

The Commission preliminarily believes that this requirement is already accounted for in the existing information collections burdens associated with Rule 613 and the CAT NMS Plan Approval Order submitted under OMB number 3235-0671.[592] Specifically, the CAT NMS Plan Approval Order takes into account requirements on broker-dealer members to record and report CAT Data to the Central Repository in accordance with specified timelines, including customer information.

E. Collection of Information is Mandatory

Each collection of information discussed above would be a mandatory collection of information.

F. Confidentiality of Responses to Collection of Information

---

30 hours include 6 hours by an Attorney, 6 hours by a Compliance Manager, 6 hours by a Senior Systems Analyst, 6 hours by an Assistant General Counsel, 3 hours by the Chief Compliance Officer and 3 hours by the Chief Information Security Officer. The ongoing external cost of this obligation is preliminarily estimated to be $12,324 = (Attorney for 6 hours at $426 per hour = $2,556) + (Compliance Manager for 6 hours at $317 per hour = $1,902) + (Senior Systems Analyst for 6 hours at $291 per hour = $1,746) + (Assistant General Counsel for 6 hours at $477 per hour = $2,862) + (Chief Compliance Officer for 3 hours at $543 per hour = $1,629) + (Chief Information Security Officer for 3 hours at $543 per hour = $1,629).

591 $42,205 / 25 Participants = $1,688.20 per Participant.

592 See, CAT NMS Plan Approval Order, supra note 3, at 84911-43.

The Commission preliminarily believes that all information required to be submitted to the Commission under the proposed amendments, including the evaluation of the Plan Processor's performance under proposed Section 6.6(b)(ii)(B)(3), the examination reports required by proposed Section 6.5(g)(v), the application materials for non-SAW environments as required under proposed Section 6.13(d), the annual Regular Written Assessment of the Plan Processor under proposed Section 6.6(b)(ii)(A) and the application for Programmatic CAIS Access and Programmatic CCID Subsystem Access under proposed Appendix D, Section 4.1.6 should be protected from disclosure subject to the provisions of applicable law.[593]

Public disclosure of other collections of information could raise concerns about the security of the CAT and therefore the Commission preliminarily believes that the Plan Processor and the Participants, as applicable, would keep these materials confidential.[594] Such collections of information include the development of SAW-specific provisions for the CISP and related policies, procedures, and security controls required pursuant to proposed Section 6.13(a); the

---

593 See, e.g., 5 U.S.C. 552 et seq.; 15 U.S.C. 78x (governing the public availability of information obtained by the Commission).

594 The Participants must comply with the security plan developed by the Plan Processor pursuant to Appendix D, Section 4.1 of the CAT NMS Plan and any security-related policies and procedures developed pursuant to Regulation SCI. See CAT NMS Plan, supra note 3, at Appendix D, Section 4.1 (requiring the Plan Processor to provide to the Operating Committee a comprehensive security plan, including a process for responding to security incidents and reporting of such incidents); 17 CFR 242.1001 (requiring each SCI entity to establish, maintain, and enforce written policies and procedures reasonably designed to ensure that its SCI systems have levels of security adequate to maintain operational capabilities and promote the maintenance of fair and orderly markets). In some cases, non-member invitees of the Security Working Group may be given access to otherwise confidential information, but the Commission believes that the CISO and the Operating Committee should consider requiring any non-member invitees sign a non-disclosure agreement or adhere to some other protocol designed to prevent the release of confidential information regarding the security of the CAT System. Members of the Security Working Group (and their designees) would be subject to the confidentiality obligations set forth in Section 9.6 of the CAT NMS Plan.

development of the detailed design specifications required pursuant to proposed Section 6.13(b)(i); the evaluation of each Participant's SAW and related notification to the Operating Committee under proposed Section 6.13(b)(ii), the monitoring of SAWs and non-SAW environments and notification of non-compliance events required by proposed Section 6.13(c)(i) and proposed Section 6.13(d)(iii); the collection of application materials for an exception to the proposed SAW usage requirements pursuant to proposed Section 6.13(d); the development of policies and procedures for review of such applications and the issuance of exceptions to the SAW usage requirements by the CISO and the CCO pursuant to proposed Section 6.13(d); and the audit trail of access to Customer Identifying Systems and the daily reports of users entitled to access Customer Identifying Systems as required by the proposed amendments to Section 4.1.6 of Appendix D.

Finally, the policies required by proposed Section 6.5(g)(i) would not be confidential. Rather, the proposed rule would require Participants to make the policies required by Section 6.5(g)(i) publicly available on each of the Participant websites, or collectively on the CAT NMS Plan website, redacted of sensitive proprietary information.

G. Retention Period for Recordkeeping Requirements

National securities exchanges and national securities associations would be required to retain records and information pursuant to Rule 17a-1 under the Exchange Act.[595] The Plan Processor would be required to retain the information reported to Rule 613(c)(7) and (e)(6) for a period of not less than five years.[596]

H. Request for Comments

Pursuant to 44 U.S.C. 3506(c)(2)(B), the Commission solicits comments to:

---

595 See 17 CFR 242.17a-1.

596 See 17 CFR 242.613.

175. Evaluate whether the proposed collections of information are necessary for the proper performance of the functions of the agency, including whether the information shall have practical utility;

176. Evaluate the accuracy of our estimates of the burden of the proposed collection of information;

177. Determine whether there are ways to enhance the quality, utility, and clarity of the information to be collected; and

178. Evaluate whether there are ways to minimize the burden of collection of information on those who are to respond, including through the use of automated collection techniques or other forms of information technology.

Persons submitting comments on the collection of information requirements should direct them to the Office of Management and Budget, Attention: Desk Officer for the Securities and Exchange Commission, Office of Information and Regulatory Affairs, Washington, DC 20503, and should also send a copy of their comments to Secretary, Securities and Exchange Commission, 100 F Street NE, Washington, DC 20549-1090, with reference to File Number 4-698. Requests for materials submitted to OMB by the Commission with regard to this collection of information should be in writing, with reference to File Number 4-698 and be submitted to the Securities and Exchange Commission, Office of FOIA/PA Services, 100 F Street NE, Washington, DC 20549-2736. As OMB is required to make a decision concerning the collection of information between 30 and 60 days after publication, a comment to OMB is best assured of having its full effect if OMB receives it within 30 days of publication.

IV. Economic Analysis

Section 3(f) of the Exchange Act requires the Commission, whenever it engages in rulemaking and is required to consider or determine whether an action is necessary or appropriate in the public interest, to consider, in addition to the protection of investors, whether the action would promote efficiency, competition, and capital formation.[597] In addition, Section 23(a)(2) of the Exchange Act requires the Commission, when making rules under the Exchange Act, to consider the impact such rules would have on competition.[598] Exchange Act Section 23(a)(2) prohibits the Commission from adopting any rule that would impose a burden on competition not necessary or appropriate in furtherance of the purposes of the Exchange Act. The discussion below addresses the likely economic effects of the proposed rule, including the likely effect of the proposed rule on efficiency, competition, and capital formation.

The Commission is proposing amendments to the CAT NMS Plan that would (1) define the scope of the current information security program; (2) require the Operating Committee to establish and maintain a security-focused working group; (3) require the Plan Processor to create SAWs, direct Participants to use such workspaces to access and analyze PII and CAT Data obtained through the user-defined direct query and bulk extract tools described in Section 6.10(c)(i)(B) of the CAT NMS Plan, set forth requirements for the data extraction, security, implementation and operational controls that will apply to such workspaces, and provide an exception process that will enable Participants to use the user-defined direct query and bulk extract tools in other environments; (4) limit the amount of CAT Data that can be extracted from the Central Repository outside of a secure analytical workspace through the online targeted

---

[597] 15 U.S.C. 78c(f).

[598] 15 U.S.C. 78w(a)(2).

query tool described in Section 6.10(c)(i)(A) of the CAT NMS Plan and require the Plan Processor to implement more stringent monitoring controls on such data; (5) impose requirements related to the reporting of certain PII; (6) define the workflow process that should be applied to govern access to customer and account attributes that will still be reported to the Central Repository; (7) modify and supplement existing requirements relating to Participant policies and procedures regarding the confidentiality of CAT Data; (8) refine the existing requirement that CAT Data be used only for regulatory or surveillance purposes; (9) codify existing practices and enhance the security of connectivity to the CAT infrastructure; (10) require the formal cyber incident response plan to incorporate corrective actions and breach notifications; (11) amend reporting requirements relating to Firm Designated IDs and Allocation Reports; and (12) clarify that Appendix C of the CAT NMS Plan has not been updated to reflect subsequent amendments to the CAT NMS Plan.

A. Analysis of Baseline, Costs and Benefits

The Commission preliminarily believes the proposed amendments would improve the security of CAT Data through a number of mechanisms. The amendments are likely to reduce the attack surface of CAT by further limiting the extraction of CAT Data beyond the security perimeter of the CAT System. In addition, the proposed amendments may increase the uniformity of security monitoring across environments from which CAT Data is accessed and analyzed by facilitating centralized monitoring by the Plan Processor. In addition, the Commission preliminarily believes that provisions allowing for exceptions to the SAW usage requirement may allow Participants to achieve or maintain the security standards required by the CAT NMS Plan more efficiently. Additional effects upon efficiency and competition are discussed in Part IV.B.

The Commission preliminarily believes that provisions of the proposed amendments outside of the SAW use requirement will result in one-time costs of approximately $2.0MM.[599] In addition, these provisions of the proposed amendments would result in ongoing annual costs of approximately $5.9MM.[600] The Commission also preliminarily estimates that depending on the number of Participants that choose to work within SAWs, the SAW or exception requirement will entail $4.9MM to $61.6MM in initial costs and $4.7MM to $32.8MM in ongoing annual costs. These costs are summarized in Table 1 and Table 2[601] below, and discussed further in the sections that follow.

Table 1:

Summary of costs other than SAW costs ($)

	Participants		Plan Processor	
Activity	**Labor**	**External**	**Labor**	**External**
Initial				
OTQT logging			88,000	
CAIS programmatic access			620,200	
Policies and procedures	1,155,900	50,000	10,900	
Regulator and Plan Processor access			10,300	
Secure connectivity			33,100	
Breach management policies and procedures	9,500		49,800	
Total One-Time Costs	**1,165,400**		**812,300**	
Annual				
CISP	106,400	9,000	129,900	
Security Working Group	2,056,600		310,000	

599 ($1,165,400 + $812,300) = $1,977,700.

600 ($3,613,800 + $1,451,500 + $869,200) = $5,934,500.

601 See infra Part IV.A.3.

OTQT logging	970,200		5,100
Customer Identifying Systems Workflow			373,500
Policies and procedures	480,600	1,442,500	5,400
Secure connectivity			3,100
Breach management policies and procedures			42,200
Total ongoing annual costs	**3,613,800**	**1,451,500**	**869,200**

1. CISP

In Section 6.12, the Plan requires the Plan Processor to develop and maintain an information security program for the Central Repository. Section 4 of Appendix D sets out information security requirements that cover "all components of the CAT System" and is not limited to the Central Repository.[602]

To more explicitly define the scope of the information security program referenced in Section 6.12, the proposed amendments would define the term "Comprehensive Information Security Program"[603] (CISP) to encompass the Plan Processor and the CAT System, including any systems provided or managed by external contractors, organizations or other sources. Additionally, the scope of the CISP would include the SAWs.[604]

The Commission preliminarily believes that the benefit of this provision of the proposed amendments is a potential improvement to the efficiency of CAT implementation by specifically

---

602 See supra Part II.A.

603 "Comprehensive Information Security Program" includes the organization-wide and system-specific controls and related policies and procedures required by NIST SP 800-53 that address information security for the information and information systems that support the operations of the Plan Processor and the CAT System, including those provided or managed by an external organization, contractor, or source, inclusive of Secure Analytical Workspaces. See supra Part II.A.

604 Id.